ADscan

AD PASSWORD HYGIENE REPORT

The passwords we *recovered*.

Credential material was extracted during the assessment, and these are the passwords that recovery resolved from it. An attacker with the same material recovers the same passwords.

RECOVERY RATE	PASSWORDS RECOVERED	PRIVILEGED RECOVERED
50.0%	9/18	2

Generated November 10, 2026
Scope north.sevenkingdoms.local

SAMPLE: Generated against a demonstration lab environment. Your ADscan instance generates this against your real domain in 90 seconds.

WHAT RECOVERY PROVED PASSWORD RECOVERY RESULT

We *measured* how strong these passwords are.

Credential recovery ran against the material extracted in this engagement. What it resolved is a direct measure of how guessable these passwords are: anything recovered here is recovered just as easily by an attacker who reaches the same material. What it did not resolve is reported too, below, because that is a real result about the accounts that held.

9 of 18 passwords recovered

Password recovery resolved the password of 9 of the 18 accounts whose credential material was extracted, enabled and disabled alike. Of those, 2 are administrative accounts with direct control of the domain (robb.stark, vagrant), which is where to act first. A privileged account whose password is recoverable is the first thing to change: it opens the control plane of the directory, so it is fixed ahead of anything else in this report.

TIER 0: DOMAIN CONTROL

2/7

recovered of 7 extracted (28.6%).

TIER 1: SERVER / APPLICATION ADMIN

0/2

none of 2 recovered: these held.

TIER 2: STANDARD

7/9

recovered of 9 extracted (77.8%).

HIGH-VALUE, ANY TIER

2/7

accounts the directory marks high impact, counted again here across every tier above.

WHAT TO RUN NATIVE WINDOWS AND RSAT

Fixing this, *on Monday*.

Every command below is a native Windows or RSAT ActiveDirectory cmdlet your administrator runs against the directory, with the account filled in. Nothing here needs a third-party tool. Replace each angle-bracket placeholder with the account or policy name from the tables above.

Reset every recovered password, and require a change at next logon

A recovered password is already known. Reset it and force the account to choose a new one, so the value this assessment resolved stops working immediately.

```
Set-ADAccountPassword -Identity <account> -Reset
Set-ADUser -Identity <account> -ChangePasswordAtLogon $true
```

VERIFY `Get-ADUser -Identity <account> -Properties pwdLastSet | Select-Object Name, pwdLastSet` returns a timestamp of the reset. The old password no longer authenticates.

Break every shared-password group

Accounts that share a password fall together. Reset each account in a group to its own distinct value, then enforce a policy strong enough that a weak shared value cannot be set again.

1. Reset each account in the group individually with the two commands above, giving each a distinct password.
2. Apply a fine-grained password policy to the accounts, so the floor is enforced where it matters without changing the whole domain default.

```
New-ADFineGrainedPasswordPolicy -Name "<policy_name>" -Precedence 10 `
  -MinPasswordLength 15 -ComplexityEnabled $true -PasswordHistoryCount 24
Add-ADFineGrainedPasswordPolicySubject -Identity "<policy_name>" -Subjects <account_or_group>
```

VERIFY `Get-ADUserResultantPasswordPolicy -Identity <account>` shows the fine-grained policy applied, not the weaker domain default.

Move service accounts to managed, rotating credentials

Most shared and recovered passwords sit on service accounts set once and never rotated. A group-managed service account has its password set and rotated by the directory itself, so there is no static secret to recover or reuse.

```
New-ADServiceAccount -Name "<gmsa_name>" -DNSHostName "<gmsa_name>.north.sevenkingdoms.local" `
  -PrincipalsAllowedToRetrieveManagedPassword <host_or_group>
```

VERIFY `Test-ADServiceAccount -Identity <gmsa_name>` returns True on the host once the service runs under the managed account.

Protect any privileged account, and roll the directory key if its password was recovered

A recovered privileged password reaches the whole directory. Reset it, add the account to Protected Users so it cannot be used with the weaker legacy authentication an attacker prefers, and if the directory key account itself was recovered, roll that key twice with replication allowed to complete in between.

```
Add-ADGroupMember -Identity "Protected Users" -Members <privileged_account>
```

VERIFY `Get-ADGroupMember -Identity "Protected Users"` lists the account. For the directory key account, reset it twice with one full replication cycle between resets, then confirm with `Get-ADUser krbtgt -Properties pwdLastSet`.

HOW THESE PASSWORDS WERE TESTED

A password counted as recovered only when it was resolved from the extracted material. A password that did not resolve is not proof of strength on its own; it is reported as held against the method that ran, stated here.